



Activity File: LLMNR Spoofing

In this activity, you'll continue to play the role of a pen tester conducting an engagement on MegaCorpOne. While we successfully performed password spraying and found a set of credentials that works on a domain-joined machine, we want to see if we can find any other accounts through other methods. You will perform LLMNR spoofing in order to retrieve a set of credentials for another domain user, which you will crack offline with John the Ripper.

- You will use a tool called Responder to listen for LLMNR requests and spoof responses to unsuspecting victims on the network.
- This activity will require you to play the attacker and perform some actions to capture LLMNR requests from the victim machine.

Additional tips:

- As penetration testers, you're hired to test any potential security flaws in the network.
- While you may have discovered one way of access, there may also be another. Therefore, you should not stop looking for other vulnerabilities.

 **Reminder:** Don't forget to save your findings, as you will add them to your Week 16 Homework!

Instructions

1. In Kali, launch a new terminal and run `responder` as sudo while passing in `eth1` as the device to use:
 - `sudo responder -I eth1 -v`
 - Responder will now listen for LLMNR broadcasts from all devices on the network.
2. Wait for Responder to receive the incoming LLMNR broadcast.

- Once the request is received, Responder automatically replies with an NTLM challenge asking for the password hash of the requesting user. Windows 10 receives this reply and responds with the NTLMv2 hash of the user.
 - If no hashes are captured within five minutes, restart the Windows 10 machine.
3. Once the password hash has been retrieved, copy it into a text file and crack it with **john**.